

13-2-2026

Análisis comparativo de metodologías de seguridad informática

CNO V: Seguridad Informática

Nombre:

Morales Hernández Roberto Emiliano

Matrícula:

182377

Servando López Contreras

Grupo T46A

CARTOGRAFIANDO EL PENTESTING

Introducción

Las pruebas de penetración y la evaluación de la seguridad informática son actividades fundamentales para identificar debilidades técnicas, fallas de configuración y deficiencias en los controles de seguridad de los sistemas de información. Para llevar a cabo estos procesos de forma estructurada y profesional, existen diversas metodologías y marcos de referencia que proporcionan guías, fases y criterios estandarizados.

Cada metodología de pentesting tiene un enfoque distinto, ya sea ofensivo, defensivo o evaluativo. Algunas priorizan la simulación de ataques reales, otras se enfocan en la medición objetiva de la seguridad, mientras que algunas sirven como marcos de conocimiento para detección y respuesta. Comprender estas diferencias permite seleccionar la metodología más adecuada según el tipo de sistema, el objetivo de la evaluación y el contexto organizacional.

Tabla Comparativa

METODOLOGÍA	DESCRIPCIÓN	FASES	OBJETIVO	ESCENARIO	ORIENTACIÓN	AUTORES (URL)	CERTIFICACIONES	VERSIONES
MITRE ATT&CK	Marco de conocimiento que proporciona un catálogo que documenta tácticas, técnicas y procedimientos (TTPs) utilizados por atacantes reales, basados en la observación de amenazas.	Se organiza en tácticas (no fases en sí) ▪ Reconnaissance ▪ Initial Access ▪ Execution ▪ Persistence (...)	Identificar y analizar tácticas y técnicas de ataque facilitando la detección, respuesta y mitigación de amenazas.	Empresa es víctima de un ransomware (<i>mapear las tácticas y técnicas del ataque, para fortalecerse a futuro</i>)	Defensa / evaluación (descripción de tácticas y técnicas de ataque)	The MITRE Corporation (sin fines de lucro) https://attack.mitre.org/#	No certificaciones directas. (Capacitación y cursos basados)	ATT&CK v18 - October 28, 2025 (Actualización continua)
OWASP WSTG	Guía detallada para pruebas de seguridad en aplicaciones web, enfocado en vulnerabilidades comunes, proporcionando un marco de buenas prácticas	1) Antes del inicio del desarrollo 2) Durante definición y diseño 3) Durante el desarrollo 4) Durante despliegue 5) Durante mantenimiento	Ofrecer mejores prácticas para realizar pruebas de seguridad, detectando vulnerabilidades y mejorar las aplicaciones web.	Empresa de comercio electrónico desarrollan una nueva plataforma web (<i>pruebas exhaustivas que aseguren la resistencia ante ataques comunes.</i>)	Ataque / evaluación (proporciona un conjunto completo de pruebas para evaluar)	OWASP (colaboración de una comunidad abierta) https://owasp.org/www-project-web-security-testing-guide/v42/	No certificaciones directas. (Capacitación y cursos basados)	WSTG [Version 4.2] - 2020-12-03 (Vigente)

NIST SP 800-115	Guía técnica para pruebas de seguridad y evaluación de sistemas de información, a través de analizar hallazgos y desarrollar estrategias de mitigación.	1) Planeación 2) Ejecución 3) Post-ejecución	Brindar un enfoque sistemático y escalable para la planificación y realización de pruebas de penetración.	Organización gubernamental planea realizar pruebas de penetración en su infraestructura crítica (<i>definir un plan detallado</i>)	Evaluación / defensa (directrices sobre cómo llevar a cabo pruebas de penetración)	NIST (National Metrology Institute, USA) https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nist-special-publication800-115.pdf	No certificaciones directas. (Base para capacitaciones)	SP 800-115 (Final) - 09/30/08 (Publicación vigente)
OSSTMM	Manual con una metodología para medir la seguridad operativa de sistemas enfocándose en la comunicación y el rendimiento, a través de casos de prueba de hechos verificados	1) Inducción 2) Interacción 3) Indagación 4) Intervención	Facilitar la comprensión de los controles operativos, comparandose con la modelo CIA	Startup tecnológica quiere evaluar la seguridad de su red interna (<i>generar métricas para el control de seguridad</i>)	Evaluación (marco para la evaluación de seguridad)	Creador Pete Herzog , desarrollado y mantenido por ISECOM https://www.ise.com.org/OSSTM/M.3.pdf	▪ OPST (OSSTMM Professional Security Tester) (499€) ▪ OPSA (OSSTMM Professional Security Analyst) (499€) ▪ CTA (Certified Trust Analyst) (299€)	OSSTMM v3 (vigente).
PTES	Estándar práctico para realizar pruebas de penetración, cubriendo desde la definición del alcance hasta la presentación de informes.	1) Interacciones previas al compromiso 2) Recopilación de inteligencia 3) Modelado de amenazas 4) Análisis de vulnerabilidad 5) Explotación 6) Post-explotación 7) Informes.	Estandarizar pruebas de penetración técnicas, asegurando que se sigan pasos claros y se logren resultados consistentes para la mejora.	Banco contrata una firma externa para realizar pruebas de penetración en su sistema en línea (<i>asegurar una evaluación completa y efectiva documentada</i>)	Ataque / evaluación (proporciona un marco para las pruebas de penetración)	Comunidad PTES (expertos en seguridad de la información, profesionales del pentesting) http://www.pentest-standard.org	No certificaciones directas. (Se relacionan indirectamente con OSCP, GPEN)	PTES v1.0 - Estándar estable (el marco principal sigue consolidado bajo esta estructura).
ISSAF	Metodología detallada del cómo realizar una prueba de penetración a través de pruebas de seguridad con enfoque técnico y procedimental.	1) Planificación 2) Evaluación 3) Tratamiento 4) Acreditación	Evaluación de la seguridad de los SI para identificar debilidades técnicas y organizacionales, implementando medidas necesarias.	Empresa financiera realiza una evaluación de seguridad integral (<i>proponer mejores con los hallazgos con la evaluación realizada</i>)	Ataque / evaluación (evaluaciones de seguridad de manera estructurada)	OISSG (Open Information Systems Security Group) https://pymese.org/issaf/	No certificaciones directas. (CISA incluye conceptos relacionados)	ISSAF draft 0.2 (poca actualización reciente).

Conclusión

El análisis comparativo demuestra que no existe una única metodología universal para todas las evaluaciones de seguridad. Cada marco responde a necesidades específicas y contextos distintos. Metodologías como PTES y OWASP WSTG son ideales para pruebas técnicas ofensivas, mientras que NIST SP 800-115 y OSSTMM resultan más apropiadas para auditorías formales y evaluaciones estructuradas.

Por otro lado, MITRE ATT&CK complementa estas metodologías al proporcionar una visión realista del comportamiento de los atacantes, fortaleciendo la detección y la respuesta a incidentes. En conjunto, estas metodologías permiten al profesional de seguridad adoptar un enfoque integral, combinando ataque, evaluación y defensa para mejorar la postura de seguridad de las organizaciones.

Referencias bibliográficas

- Herzog P. (2010), OSSTMM 3 – The Open Source Security Testing Methodology Manual. <https://www.isecom.org/OSSTMM.3.pdf>
- MITRE ATT&CK® (s.f.), MITRE ATT &CK. <https://attack.mitre.org>
- NIST (Scarfone K., Souppaya M., Cody A., Orebaugh A.) (Septiembre, 2008), Technical Guide to Information Security Testing and Assessment. <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf>
- OISSG (Abril, 2006), Information Systems Security Assessment Framework (ISSAF) draft 0.2. <https://untrustednetwork.net/files/issaf0.2.1.pdf>
- OWASP (s.f.), OWASP Web Security Testing Guide . <https://owasp.org/www-project-web-security-testing-guide/>
- PTES Group (s.f.), PTES Technical Guideline. http://www.pentest-standard.org/index.php/Main_Page